Sicurezza dei Sistemi Informativi

Appello d'Esame del 17 Settembre 2024

Anno Accademico 2023-2024

Politecnico di Torino — Docente: Prof. Cataldo Basile

2024-09-17

1 Testo Ufficiale dell'Esame

Domanda 1: Domande a Scelta Multipla

Valutare la correttezza delle seguenti affermazioni:

a. Se viene effettuato un port scanning TCP SYN contro un server posso identificare le porte aperte, chiuse e filtrate.

b. L'attacco di Kaminsky permette di forgiare risposte DNS false ma può essere evitato con DNSSEC.

c. Dato un keyed-digest $kd = H(k \parallel M)$, è possibile estrarre la chiave segreta k tramite un length extension attack.

d. Lo Smurf attack può essere evitato disabilitando l'inoltro di pacchetti ICMP diretti a indirizzi IP di broadcast sulla rete.

e. Il FIN scanning permette di distinguere i packet filter stateful da quelli stateless.

f. Un SYN interceptor evita che le tabelle delle connessioni dei server protetti si saturino con attacchi di flooding.

g. Il framework eIDAS stabilisce che una Qualified Electronic Signature ha lo stesso valore legale di una firma autografa.

h. Un SIEM è un particolare tipo di IPS che si integra con i firewall per bloccare automaticamente gli attacchi.

Domanda 2: Protezione di Canale e Protocollo TLS

Spiegare cosa si intende per protezione di canale e in quali contesti applicativi viene utilizzata. Indicare e descrivere in dettaglio il funzionamento del protocollo TLS, specificando:

- Quali proprietà di sicurezza garantisce (riservatezza, integrità, autenticazione, anti-replay, PFS);
- Quali tecniche e algoritmi crittografici vengono utilizzati per garantire ciascuna proprietà;
- Come il protocollo Record Layer gestisce la frammentazione, compressione (e i suoi rischi), autenticazione e cifratura dei messaggi.

Domanda 3: NIST Risk Management Framework (RMF SP 800-37)

Spiegare cosa è il Risk Management Framework (RMF) del NIST e quali sono i suoi obiettivi. Elencare e descrivere dettagliatamente le 7 fasi del ciclo di vita del framework RMF (Prepare, Categorize, Select, Implement, Assess, Authorize, Monitor), indicando le principali operazioni svolte in ciascuna fase.

Domanda 4: Common Criteria e CEM

Spiegare cosa sono i Common Criteria (ISO/IEC 15408) e a cosa servono. All'interno di questo contesto, spiegare cosa sono i Protection Profile (PP) e perché sono utili alle organizzazioni che acquistano software e apparati hardware. Infine, discutere cosa è la Common Evaluation Methodology (CEM) e come si integra con i Common Criteria per standardizzare le valutazioni condotte dai laboratori accreditati.

2 Soluzione Dettagliata e Guida Risolutiva

Soluzione Domanda 1: Valutazione Crocette

- **a. VERA**: Con il SYN scan (half-open), se riceviamo SYN/ACK la porta è aperta; se riceviamo RST la porta è chiusa; se non riceviamo risposta o riceviamo ICMP unreachable la porta è filtrata.
- **b. VERA**: L'attacco di Kaminsky inietta record falsi nella cache del resolver DNS; DNSSEC impedisce ciò firmando digitalmente i record (RRSIG).
- **c. FALSA**: Il *length extension attack* (tipico di funzioni di hash Merkle-Dåmgard come MD5, SHA-1, SHA-256) consente di calcolare un nuovo digest valido per $M \parallel \text{padding} \parallel M'$, ma **non rivela la chiave segreta k** all'attaccante.
- **d. VERA**: Lo Smurf attack inviava ping ICMP con IP spoofato della vittima a indirizzi broadcast di terze parti; disabilitare il broadcast ICMP elimina il fattore di amplificazione.
- **e. VERA**: I pacchetti FIN inviati senza connessione aperta vengono gestiti diversamente da un firewall stateful (che li scarta perché non associati a sessione attiva) rispetto a uno stateless.
- **f. VERA**: Il SYN Interceptor risponde alle richieste SYN al posto del server ed apre la connessione reale solo a handshake client completato.
- **g. VERA**: Ai sensi del Regolamento UE n. 910/2014 (eIDAS), la firma elettronica qualificata (QES) equivale pienamente a una firma autografa.
- **h. FALSA**: Il SIEM è una piattaforma di correlazione e analisi dei log (*Security Information and Event Management*), non è un IPS inline.

Soluzione Domanda 2: Protezione di Canale e Protocollo TLS

Concetto di Protezione di Canale: La protezione di canale (*Channel Security*) garantisce un canale logico punto-a-punto sicuro tra due endpoint comunicanti attraverso un'infrastruttura di rete insicura o ostile (Internet). Protegge da intercettazione passiva (eavesdropping), alterazione dei dati (tampering) e impersonificazione, garantendo che le proprietà di sicurezza siano preservate a prescindere dal numero e dalla natura dei router o nodi intermedi attraversati.

Proprietà di Sicurezza e Meccanismi Crittografici in TLS (1.2/1.3):

- **Riservatezza (Confidenzialità)**: Garantita mediante algoritmi di cifratura simmetrica autenticata (AEAD) moderni come AES-GCM (128 o 256 bit), AES-CCM o ChaCha20-Poly1305. I vecchi cifrari a blocchi in modalità CBC e cifrari stream RC4 sono deprecati/vietati.
- **Integrità e Autenticità dei Messaggi**: Garantite contestualmente dal tag crittografico di autenticazione calcolato dalla modalità AEAD (es. GHASH in GCM o Poly1305), oppure storicamente tramite HMAC (costruito su SHA-256/SHA-384).
- **Autenticazione dell'Origine (Peer Authentication)**: Garantita tramite certificati digitali X.509 firmati da Certification Authority (CA) fidate e algoritmi di firma digitale asimmetrica (RSA-PSS, ECDSA o Ed25519) scambiati durante l'handshake.

- **Perfect Forward Secrecy (PFS)**: Garantita dall'uso obbligatorio di parametri effimeri di Diffie-Hellman su curve ellittiche (ECDHE) o gruppi finiti (DHE). La distruzione delle chiavi effimere private al termine della sessione impedisce la decifratura retroattiva del traffico registrato.
- **Protezione Anti-Replay**: Garantita tramite un contatore di sequenza a 64 bit (*Sequence Number*) mantenuto implicitamente per ciascun record trasmesso da entrambe le parti ed incrementato per ogni blocco.

Il Protocollo TLS Record Layer (Funzionamento ed Elaborazione): Il Record Layer si colloca tra il livello di trasporto (TCP) e i protocolli superiori di TLS (Handshake, Alert, Application Data). Elabora i messaggi attraverso le seguenti fasi sequenziali:

1. **Frammentazione**: I blocchi di dati provenienti dai livelli applicativi superiori vengono suddivisi in frammenti gestibili di lunghezza non superiore a 2^{14} byte (16384 byte = 16 KB).
2. **Compressione e Rischi di Sicurezza (CRIME / BREACH)**: Lo standard TLS originario prevedeva una fase opzionale di compressione (es. DEFLATE) prima della cifratura. Tuttavia, ciò ha introdotto la gravissima classe di vulnerabilità note come **CRIME (CVE-2012-4929)** e **BREACH**: quando un attaccante man-in-the-middle può indurre la vittima a iniettare dati noti all'interno della richiesta HTTP e osservare la dimensione del pacchetto compresso e cifrato, le proprietà dell'algoritmo LZ77 (che comprime maggiormente sequenze ripetute) permettono di estrarre segreti byte-a-byte (es. cookie di sessione o token CSRF). Pertanto, la compressione a livello Record Layer è stata **formalmente disabilitata e vietata** da RFC 7540 e RFC 8446 (TLS 1.3).
3. **Autenticazione e Cifratura**: In TLS 1.3 si adotta esclusivamente il paradigma AEAD: il frammento plaintext viene cifrato e contestualmente viene generato il tag di autenticazione includendo come dati associati (AD) l'header del record (tipo contenuto, versione, lunghezza).
4. **Aggiunta Header TLS Record**: Viene prepeso un header di 5 byte contenente il Content Type (1 byte), la versione di protocollo Legacy (2 byte) e la lunghezza del payload (2 byte), prima della trasmissione su socket TCP.

Soluzione Domanda 3: NIST RMF (SP 800-37) — Le 7 Fasi

1. **Prepare**: Preparazione dell'organizzazione e dei sistemi, identificazione del contesto e del risk appetite.
2. **Categorize**: Categorizzazione del sistema informativo e dei dati gestiti in base all'impatto potenziale secondo FIPS 199 (Low, Moderate, High per Confidenzialità, Integrità, Disponibilità).
3. **Select**: Selezione dei controlli di sicurezza minimi (baseline) da NIST SP 800-53 e relativo tailoring.
4. **Implement**: Implementazione pratica dei controlli selezionati nell'architettura aziendale.
5. **Assess**: Valutazione formale dell'efficacia dei controlli da parte di assessor indipendenti per verificare che operino come previsto.

6. **Authorize**: Decisione formale dell'Official autorizzante sull'accettabilità del rischio residuo (*Authority to Operate - ATO*).

7. **Monitor**: Monitoraggio continuo della postura di sicurezza, scansione di nuove vulnerabilità e gestione dei cambiamenti.

Soluzione Domanda 4: Common Criteria (ISO 15408) e CEM

Ruolo dei Protection Profile (PP): Un Protection Profile consente ai clienti/acquirenti di definire a priori un insieme standardizzato e formalizzato di requisiti funzionali e di garanzia per un'intera categoria di prodotti (es. "Protection Profile for Stateful Traffic Filtering Firewalls"). I produttori certificano il loro TOE a fronte di tale PP, consentendo ai clienti di confrontare oggettivamente le soluzioni di mercato.
Common Evaluation Methodology (CEM): La CEM è il manuale metodologico standardizzato (ISO/IEC 18045) utilizzato dai valutatori dei laboratori accreditati (ITSEF). Definisce le procedure passo-passo minime, le tecniche di prova e le metriche di verifica per ciascun requisito di garanzia (SAR), garantendo che valutazioni condotte da laboratori differenti in nazioni diverse producano risultati uniformi, ripetibili e reciprocamente riconosciuti.

Alternative Implementation Note: Concorrenza Rust per Applicazioni Web Sicure

Nello sviluppo di web server resilienti e sicuri secondo le linee guida NIST:

- Si adotta il runtime asincrono `tokio` con primitive di sincronizzazione non bloccanti (`tokio::sync::mpsc`, `tokio::sync::watch`).
- Per la gestione dello stato globale condiviso in sola lettura tra le richieste, si utilizza `std::sync::Arc<AppState>` combinato con tipi atomici (`AtomicUsize`) per il rate limiting e la protezione da attacchi DoS/flooding.